

Documentation : Audit de sécurité Active Directory (UCS-AD) avec PingCastle.

1. Présentation de l'outil

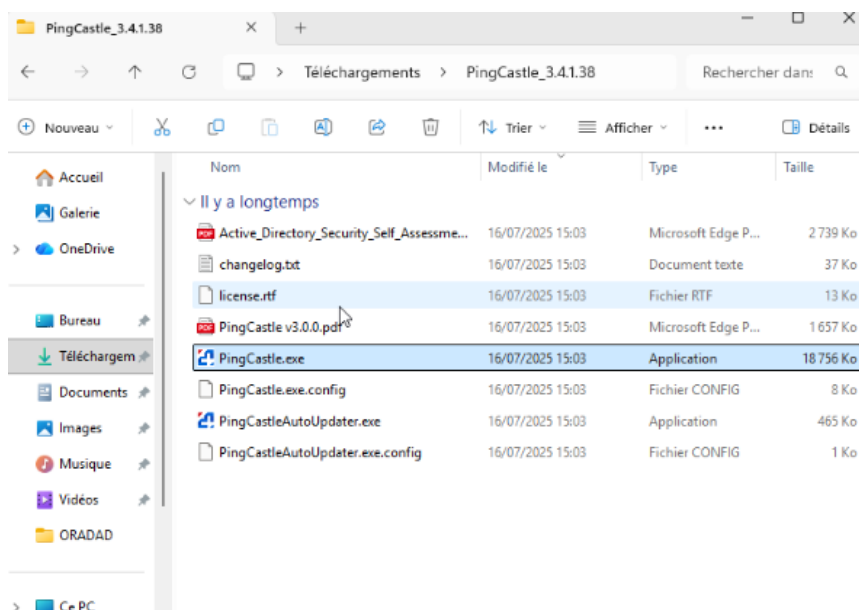
PingCastle est un outil de référence pour auditer la sécurité d'un domaine Active Directory (AD). Il évalue le niveau de risque global et détaille les vulnérabilités par catégories afin de proposer un plan d'action correctif.

2. Préparation et Lancement

L'outil se présente sous la forme d'une archive contenant un exécutable Windows. Il doit être lancé depuis un poste joint au domaine (ex: Windows 11) avec des privilèges d'administration pour un scan complet.

Procédure de lancement :

1. **Extraction** : Décompressez l'archive PingCastle_3.4.1.38.zip.
2. **Exécution** : Lancez le programme via le fichier PingCastle.exe.



3. Configuration du Scan (Interactif)

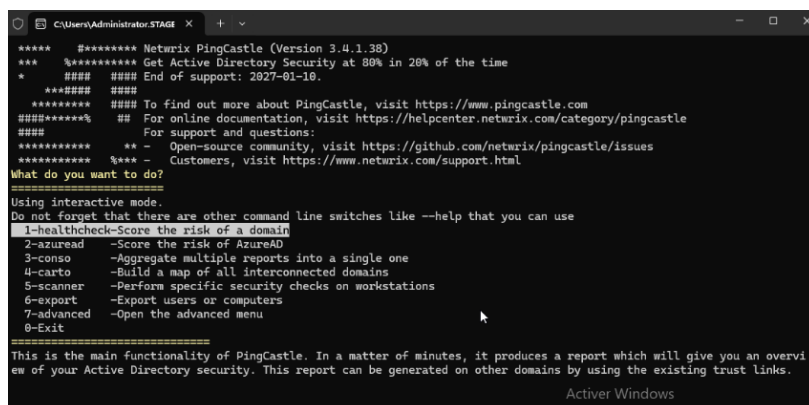
Une fois lancé, l'outil propose un menu interactif dans une console. Voici les étapes à suivre

selon vos captures :

Étape 1 : Choix de la fonctionnalité

Sélectionnez l'option principale pour évaluer le risque du domaine.

- **Action** : Tapez 1
- **Commande** : 1-healthcheck-Score the risk of a domain

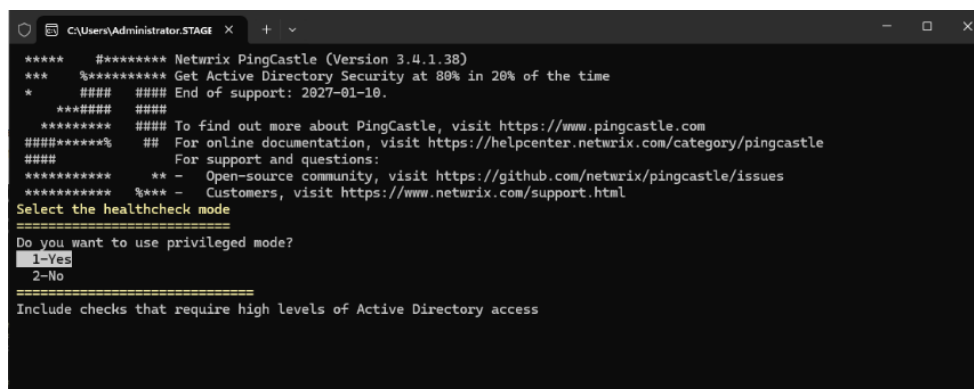


```
***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html
What do you want to do?
=====
Using interactive mode.
Do not forget that there are other command line switches like --help that you can use
1-healthcheck-Score the risk of a domain
2-azuread -Score the risk of AzureAD
3-conso -Aggregate multiple reports into a single one
4-carto -Build a map of all interconnected domains
5-scanner -Perform specific security checks on workstations
6-export -Export users or computers
7-advanced -Open the advanced menu
0-Exit
=====
This is the main functionality of PingCastle. In a matter of minutes, it produces a report which will give you an overview of your Active Directory security. This report can be generated on other domains by using the existing trust links.
Active Windows
https://www.netwrix.com/support.html
```

Étape 2 : Mode de privilèges

Pour obtenir tous les détails techniques, activez le mode privilégié.

- **Action** : Tapez 1
- **Commande** : 1-Yes (Include checks that require high levels of Active Directory access)



```
***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
#####
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
#####% ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html
Select the healthcheck mode
=====
Do you want to use privileged mode?
1-Yes
2-No
=====
Include checks that require high levels of Active Directory access
Active Windows
https://www.netwrix.com/support.html
```

Étape 3 : Sélection du domaine

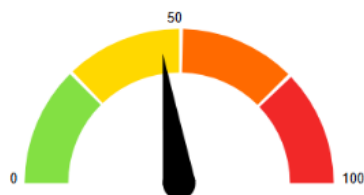
Spécifiez le domaine à analyser. Par défaut, l'outil détecte celui de votre session.

- **Action** : Appuyez sur **Entrée** pour valider le domaine par défaut.
- **Cible** : stage.local

```
C:\Users\Administrator\STAGE x + v
***** Netwrix PingCastle (Version 3.4.1.38)
*** %***** Get Active Directory Security at 80% in 20% of the time
* ##### End of support: 2027-01-10.
*****
***** ##### To find out more about PingCastle, visit https://www.pingcastle.com
##### ## For online documentation, visit https://helpcenter.netwrix.com/category/pingcastle
##### For support and questions:
***** ** - Open-source community, visit https://github.com/netwrix/pingcastle/issues
***** %*** - Customers, visit https://www.netwrix.com/support.html
Select a domain or server
=====
Please specify the domain or server to investigate (default:stage.local)
|
```

```
C:\Users\Administrator\STAGE x + v
[12:19:30] - Collecting objects - Iteration 2
[12:19:31] - Collecting objects - Iteration 3
[12:19:31] - Collecting objects - Iteration 4
[12:19:31] - Collecting objects - Iteration 5
[12:19:31] - Completing object collection
[12:19:31] - Export completed
[12:19:31] Gathering delegation data
[12:19:32] Gathering gpo data
[12:19:33] Gathering pki data
[12:19:33] Gathering sccm data
[12:19:33] Gathering exchange data
[12:19:33] Gathering anomaly data
[12:19:37] Gathering dns data
[12:19:39] Gathering WSUS data
[12:19:39] Gathering MSOL data
[12:19:39] Gathering domain controller data (including null session) (including RPC tests)
[12:19:48] Gathering network data
[12:19:48] Computing risks
[12:19:49] Export completed
[12:19:49] Generating html report
[12:19:50] Generating xml file for consolidation report
[12:19:50] Export level is Normal
[12:19:50] Personal data will NOT be included in the .xml file (add --level Full to add it. Ex: PingCastle.exe --interactive --level Full)
[12:19:53] Done
Task Perform analysis for stage.local completed
=====
Program launched in interactive mode - press any key to terminate the program
=====
```

Indicators

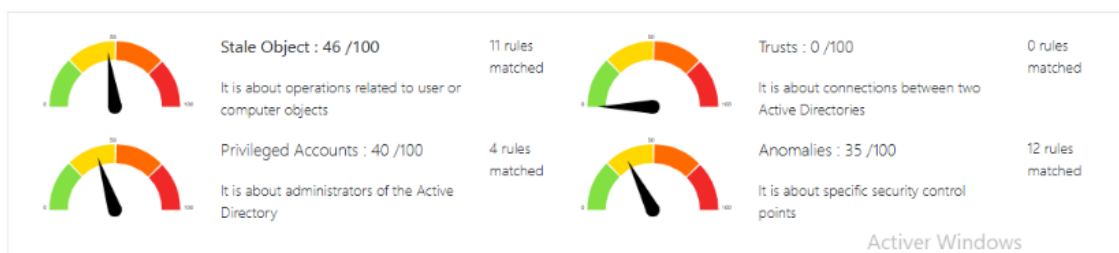


Domain Risk Level: 46 / 100

It is the maximum score of the 4 indicators and one score cannot be higher than 100. The lower the better

[Compare with statistics](#)

[Privacy notice](#)



Activer Windows

Accédez aux paramètres pour activer Windows

Domain Risk Level : 46 / 100. Le domaine se situe dans la zone **jaune**, ce qui signifie qu'il y a des vulnérabilités modérées à corriger.

Indicateur le plus critique : Stale Objects (46/100). Cela concerne souvent des comptes ou des ordinateurs inactifs ou mal nettoyés dans l'annuaire.

Comptes privilégiés (40/100) : PingCastle a détecté 4 règles correspondant à des risques sur les comptes administrateurs.

Stale Objects	Privileged accounts	Trusts	Anomalies
Inactive user or computer	Account take over	Old trust protocol	Audit
Network topography	ACL Check	SID Filtering	Backup
Object configuration	Admin control	SIDHistory	Certificate take over
Obsolete OS	Control paths	Trust impermeability	Golden ticket
Old authentication protocols	Delegation Check	Trust inactive	Local group vulnerability
Provisioning	Irreversible change	Trust with Azure	Network sniffing
Replication	Privilege control		Pass-the-credential
Vulnerability management	Read-Only Domain Controllers		Password retrieval
			Reconnaissance
			Temporary admins
			Weak password

Legend:

	score is 0 - no risk identified
	score is 0 - no risk identified but some improvements detected
	score between 1 and 10 - a few actions have been identified
	score between 10 and 30 - rules should be looked with attention
	score higher than 30 - major risks identified

Le code couleur de PingCastle est simple : **Orange** signifie que les règles doivent être examinées avec attention (score entre 10 et 30), et **Jaune** indique quelques actions identifiées.

Stale Objects rule details [11 rules matched on a total of 56]

Presence of wrong primary group for users: 3	+ 15 Point(s)
The LAN Manager Authentication Level allows the use of NTLMv1 or LM.	+ 15 Point(s)
Non-admin users can add up to 10 computer(s) to a domain	+ 10 Point(s)
The subnet declaration is incomplete (2 IP of DC not found in declared subnets)	+ 5 Point(s)
Number of accounts which have never expiring passwords: 1	+ 1 Point(s)
The functional level is below Windows Server 2012 R2.	Informative rule
Presence of service accounts without AES support = 4	Informative rule
Some script extensions used in phishing can be directly run by double clicking on it	Informative rule
Not all possible Defender ASR mitigations are in Block or Warn mode	Informative rule
It is possible for scripts engine used by hackers to connect directly to the Internet	Activer Windows Accédez aux paramètres pour activer Windows Defender Informative rule
The GPO are not pushing recommended configuration for Terminal Services	Informative rule

Analyse détaillée des règles "Stale Objects" (Hygiène de l'AD)

PingCastle a identifié 11 règles correspondantes dans cette catégorie :

- **NTLMv1 ou LM autorisé (+15 points)** : Le serveur UCS autorise encore des protocoles d'authentification obsolètes et très faciles à pirater. C'est une vulnérabilité majeure qui complète les failles SMB déjà trouvées.
- **Groupe primaire incorrect pour les utilisateurs (+15 points)** : 3 utilisateurs ont un paramétrage de groupe primaire qui ne respecte pas les bonnes pratiques de sécurité.
- **Ajout de machines par des non-admins (+10 points)** : Par défaut, n'importe quel utilisateur peut joindre jusqu'à 10 ordinateurs au domaine. Un attaquant pourrait utiliser cela pour introduire des machines malveillantes sur le réseau stage.local.
- **Déclaration de sous-réseau incomplète (+5 points)** : Deux adresses IP du contrôleur de domaine ne sont pas trouvées dans les sous-réseaux déclarés. Cela peut causer des problèmes de performance et de localisation des services.

Privileged Accounts rule details [4 rules matched on a total of 46]

Presence of Admin accounts which do not have the flag "This account is sensitive and cannot be delegated": 1	+ 20 Point(s)
The group Schema Admins is not empty: 1 account(s)	+ 10 Point(s)
The Recycle Bin is not enabled	+ 10 Point(s)
OU without the accidental deletion protection have been found	Informative rule

Détails des comptes privilégiés (Privileged Accounts)

PingCastle a identifié 4 règles spécifiques qui expliquent ton score de risque dans cette catégorie :

- **Comptes administrateurs non protégés contre la délégation (+20 points)** : Un compte administrateur n'a pas le flag "Ce compte est sensible et ne peut pas être délégué". Sans cela, un attaquant qui pirate un service sur lequel cet admin s'est connecté peut voler son identité pour rebondir sur le contrôleur de domaine (attaque par délégation).
- **Groupe "Schema Admins" non vide (+10 points)** : Ce groupe, qui permet de modifier la structure même de l'AD, contient un compte. La bonne pratique veut que ce groupe soit vidé et utilisé uniquement lors de mises à jour majeures du schéma.
- **Corbeille AD non activée (+10 points)** : La "Recycle Bin" n'est pas activée. En cas de suppression accidentelle d'un utilisateur ou d'une Unité d'Organisation (OU), la restauration sera beaucoup plus complexe.
- **Unités d'Organisation (OU) sans protection contre la suppression accidentelle** : Certaines des structures d'annuaire ne sont pas verrouillées. Un simple clic droit malheureux pourrait supprimer toute une branche d'utilisateurs.

Anomalies rule details [12 rules matched on a total of 73]

LAPS doesn't seem to be installed	+ 15 Point(s)
The audit policy on domain controllers does not collect key events.	+ 10 Point(s)
The number of DCs is too small to provide redundancy: 1 DC	+ 5 Point(s)
Hardened Paths have been modified to lower the security level	+ 5 Point(s)
DsHeuristics has not been set to enable the mitigation for CVE-2021-42291	Informative rule
No password policy for service accounts found (MinimumPasswordLength >= 20)	Informative rule
The PowerShell audit configuration is not fully enabled.	Informative rule
No GPO has been found which implements NetCease	Informative rule
The PreWin2000 compatible group contains "Authenticated Users"	Informative rule
Authenticated Users can create DNS records	Informative rule
At least one DC is using Tls1.0 or Tls1.1.	Informative rule

Activer Windows

Accédez aux paramètres pour activer Windows

Détail des Anomalies (12 règles identifiées)

PingCastle a relevé plusieurs points faibles dans la configuration de sécurité profonde du domaine stage.local :

- **LAPS n'est pas installé (+15 points)** : L'outil *Local Administrator Password Solution* est absent. Sans lui, les mots de passe des administrateurs locaux des machines jointes au domaine ne sont pas gérés de manière unique et aléatoire, ce qui facilite les mouvements latéraux d'un pirate.
- **Politique d'audit incomplète (+10 points)** : Les contrôleurs de domaine ne collectent pas les événements clés (logs). En cas d'intrusion, il sera très difficile de retracer les actions de l'attaquant.
- **Absence de redondance (+5 points)** : L'infrastructure ne possède qu'un seul contrôleur de domaine (1 DC). S'il tombe en panne, tout l'annuaire devient indisponible.
- **Hardened Paths modifiés (+5 points)** : Les chemins d'accès sécurisés ont été altérés, ce qui abaisse le niveau de protection contre l'exécution de scripts malveillants.

6. Synthèse des Recommandations

Pour abaisser le score de risque sous la barre des 30 (zone Verte), les actions suivantes sont prioritaires :

1. Désactiver **NTLMv1** et forcer **SMB Signing**³¹.
2. Activer la **corbeille Active Directory**.
3. Cocher l'option "Ce compte est sensible et ne peut pas être délégué" sur les comptes admins.
4. Déployer **LAPS** pour sécuriser les postes de travail.